

Tổng Hợp Kiến Thức

1. Khái niệm cơ bản

- **Authentication (Xác thực):** Xác minh **bạn là ai** (ví dụ: đăng nhập).
- **Authorization (Ủy quyền):** Xác định **bạn được làm gì** (ví dụ: quyền admin).
 - (Trong bài này tập trung vào Authentication).

2. Quy trình JWT

- **JWT (JSON Web Token):** Chuỗi JSON được mã hóa, chứa thông tin user, được **ký số** bởi server. Dùng làm **Access Token**.
- **Đăng nhập (Login):**
 1. **Frontend:** Gửi username/password đến `/api/login`.
 2. **Backend:** Xác thực, tạo JWT (Access Token).
 3. **Backend:** Trả Access Token về Frontend.
 4. **Frontend:** Lưu Access Token (vào `localStorage`).
- **Gọi API cần xác thực:**
 1. **Frontend:** Gửi request kèm `Authorization: Bearer <accessToken>` header.
 2. **Backend:** Kiểm tra tính hợp lệ của Access Token (chữ ký, hạn sử dụng).
 3. **Backend:** Nếu hợp lệ → Xử lý request. Nếu không hợp lệ → Trả lỗi 401/403.
- **Đăng xuất (Logout):**
 1. **Frontend:** Xóa Access Token khỏi `localStorage`.